

面向 NFV 的安全参考架构

Abdulrahman Khalid Alnaim, Ahmed Mahmoud Alwakeel and Eduardo B. Fernandez

通讯作者: aalnaim@kfu.edu.sa

摘要: 网络功能虚拟化 (NFV) 是一种新兴技术, 由于其诸多优势而变得越来越重要。NFV 将基于硬件的传统网络基础设施转变为基于软件的虚拟化网络。这种转变增加了网络的灵活性和可扩展性, 同时减少了创建新网络的时间。然而, 网络的攻击面也增加了, 这就需要明确界定可能发生攻击的位置。欧洲电信标准协会 (ETSI) 标准精确地定义了该架构的许多安全方面, 但这些出版物篇幅很长且提供了许多软件架构师不感兴趣的细节。我们首先对一些 NFV 用例进行威胁分析。这些用例可作为列举架构所面临威胁的场景。将威胁表示为描述攻击者作案手法的误用案例, 我们可以找到以安全模式形式存在的对策, 并构建一个安全参考架构 (SRA)。到目前为止, 只有不精确的 NFV 架构模型存在; 通过使其更详细和精确, 不仅可以处理安全问题, 还可以处理安全可靠性问题, 尽管我们不探讨这些方面。由于安全是一个需要整体方法的全局属性, 我们坚信架构模型对于构建安全网络至关重要, 并允许我们构建具有设计安全性的网络。由此产生的 SRA 定义了实现安全具体架构的路线图。

关键词: 网络功能虚拟化, 虚拟网络功能, 云计算, 参考架构, 安全参考架构, 模式, 虚拟机环境, 欧洲电信标准协会 (ETSI)

1 引言

为了向客户提供网络服务, 电信服务公司 (Telcos) 需要大量的硬件设备。随着用户对新网络服务需求的增长, 电信公司必须投入更多的时间和资源为每个网络功能部署物理硬件和设备, 此外还需要高技能的网络技术人员和操作人员来处理大型网络的设置和管理复杂性。而且, 由于硬件的快速发展, 网络生命周期变得更短。因此, 电信公司的运营费用 (OPEX) 和资本支出 (CAPEX) 预计会增加。

网络功能虚拟化 (NFV) 利用虚拟化技术来提供网络功能 (NFs), 如负载均衡器、交换机、防火墙、域名服务器 (DNS) 等, 这些功能是用软件构建并作为服务提供的; 它允许在虚拟机 (VMs) 中使用云基础设施而不是物理基础设施来执行 NFs。将网络设备转化为虚拟网络设备减少了在客户场所安装、维护和获取特殊硬件的需求, 并降低了能耗和成本。此外, NFV 的灵活性促使网络运营商采用它, 因为它具有网络服务的自我管理能力和创建一个促进新业务发展的新市场的能力。而且, NFV 具有以下优势:

1. 自给自足: 软件不再与硬件相关联。因此, 它们将相互独立发展。
2. 灵活性和速度: 通过将软件与硬件解耦, 可以重新分配和共享基础设施资源, 允许在不同时间执行不同的功能。因此, 网络操作及其连接可以更快速、更灵活地部署。

3. 可扩展性：在传统的遗留网络系统中，电信公司必须跟上新的网络标准和要求，这需要时间、规划和资金。然而，在 NFV 中，将软件与硬件解耦允许以更精细的粒度和最小的努力动态扩展虚拟化网络功能的实际性能。
4. 降低能耗：通过能够扩展或缩减资源，电信公司将能够减少运行网络设备所需的 OPEX。同样，由于不需要安装专用硬件来提供网络功能，客户端的能耗也将显著降低。
5. 网络设置速度：NFV 中的网络服务部署和配置要快得多。

2012 年 10 月，网络功能虚拟化作为一个新概念由欧洲电信标准协会（ETSI）提出。ETSI 在电信供应商的贡献下，提出了第一个 NFV 架构。他们的架构由三个主要架构组件组成：网络功能虚拟化基础设施（NFVI），它包含支持虚拟化网络功能执行的所有硬件和软件组件；虚拟网络功能（VNFs），它是网络功能的软件实现；以及管理和网络编排（MANO），它涵盖了 VNF 生命周期管理以及物理和软件资源的编排。

尽管 NFV 有其优势，但它增加了系统复杂性并容易受到新的威胁，这使得理解其安全问题变得重要。由于它们依赖于软件，NFV 中的网络功能可以由外部实体（如第三方提供商或消费者）配置和控制。这使得操纵网络服务比在传统网络基础设施中更容易。一般来说，与传统网络基础设施相比，NFV 的攻击面大大增加。除了传统网络基础设施中的网络资源（交换机、路由器、负载均衡器等）外，整个虚拟化环境（包括实时迁移和多租户基础设施）可能比传统网络面临更多的威胁。NFV 是 5G 网络的一项基础技术，这表明 NFV 安全的重要性将显著增加。另一个经常用于实现 NFV 的重要技术是软件定义网络（SDN）。5G 和 SDN 中的安全问题已经在一些研究中得到了探讨；NFV 需要云计算的支持，其威胁也在许多出版物中得到了研究。我们这里只专注于对 NFV 的一些安全方面进行建模。

由于安全是一个需要整体方法的全局属性，我们坚信架构模型对于构建安全网络至关重要，并允许我们构建具有设计安全性的网络。因此，我们首先通过分析 NFV 用例来寻找可能的威胁。这些用例可作为列举架构所面临威胁的场景。将威胁表示为描述攻击者作案手法的误用案例，我们可以找到以安全模式形式存在的对策，并构建一个安全参考架构（SRA）。安全模式是安全问题的封装解决方案，而误用模式则从攻击者的角度描述攻击。到目前为止，只有不精确的 NFV 架构模型存在；通过使其更详细和精确，不仅可以处理安全问题，还可以处理安全可靠性问题，尽管我们不探讨这些方面。由此产生的 SRA 定义了实现安全具体架构的路线图。据我们所知，除了 [8]（它开发了一种描述 NFV 的一般概念、其优缺点的架构模式）之外，没有工作将架构建模（即模式和参考架构）应用于描述和分析 NFV 系统。总之，我们的安全参考架构是 NFV 唯一详细的 SRA。鉴于 SRA 的范围大且具有重复性特征，我们只展示部分 SRA 并说明如何完成它。

此外，利用我们对 NFV 主要安全威胁的调查，我们分析用例以列举它们的威胁。然后，我们展示一些已识别的威胁如何可能导致几种信息误用，并使用误用模式描述其中的三种：特权提升、虚拟机逃逸和分布式拒绝服务。这些误用案例展示了我们如何选择安全模式作为对策，从而形成 SRA。这些模式已经在会议上由我们发表；在这里，我们描述它们的摘要以展示它们如何对 SRA 的功能做出贡献。模式在安全软件开发中被广泛接受，并且有一些目录使它们的使用变得方便。其他质量因素如安全可靠性不在我们的研究范围内，它们的方法和解决方案与安全不同。

本文的其余部分结构如下：第 2 节提供了关于 ETSI 提出的 NFV 架构以及模式和参考架构的背景知识。第 3 节展示了构建 NFV 安全参考架构的步骤，首先通过误

用活动列举威胁，以及这些威胁如何导致几种误用；展示了三种误用模式。该节还展示了缓解已识别误用的安全机制，并因此为 NFV 生成了一个部分安全参考架构。第 4 节展示了我们模型的一些验证方面。第 5 节考虑了相关工作。第 6 节提供了结论和未来工作。

2 背景

2.1 NFV 架构

网络功能虚拟化基础设施（NFVI）是 NFV 的基础平台，包含构成 VNFs 部署、管理和执行的基础设施的硬件和虚拟实例。NFVI 可被视为云基础设施即服务（IaaS）的一个组件，它允许云提供商建立虚拟数据中心（VDCs），这些虚拟数据中心包含作为物理数据中心运行所需的所有虚拟化计算、存储和网络资源。这些 VDCs 被提供给 NFV 提供商，他们使用它们为客户提供网络服务。提供给特定 NFV 提供商的 VDC 资源应该与其他提供商的资源隔离；这种隔离允许 NFV 提供商以安全的方式共享相同的云基础设施。当涉及到 NFV 服务时，VNFs 在 VDC 内的虚拟机（VMs）上部署。

NFVI 由三个基本组件组成，如图 1 所示。首先是硬件资源，包括计算设施（通常是商用现货（COTS）设备）、存储硬件（可能是直接连接的硬盘、外部存储区域网络（SAN）或网络连接存储（NAS）形式）以及网络硬件（可能是通过虚拟化层为 VNFs 提供处理和连接能力的交换机 / 路由器）。虚拟机监视器（VMM）（也称为 hypervisor）是虚拟化层的一部分，它位于硬件资源层之上，执行三个主要功能：将虚拟资源与底层物理资源解耦、提供 VMs 之间的隔离以及模拟硬件资源。第三，虚拟基础设施位于虚拟化层之上，并包含虚拟化资源，如虚拟机、虚拟存储和虚拟网络，这些是硬件资源的抽象。

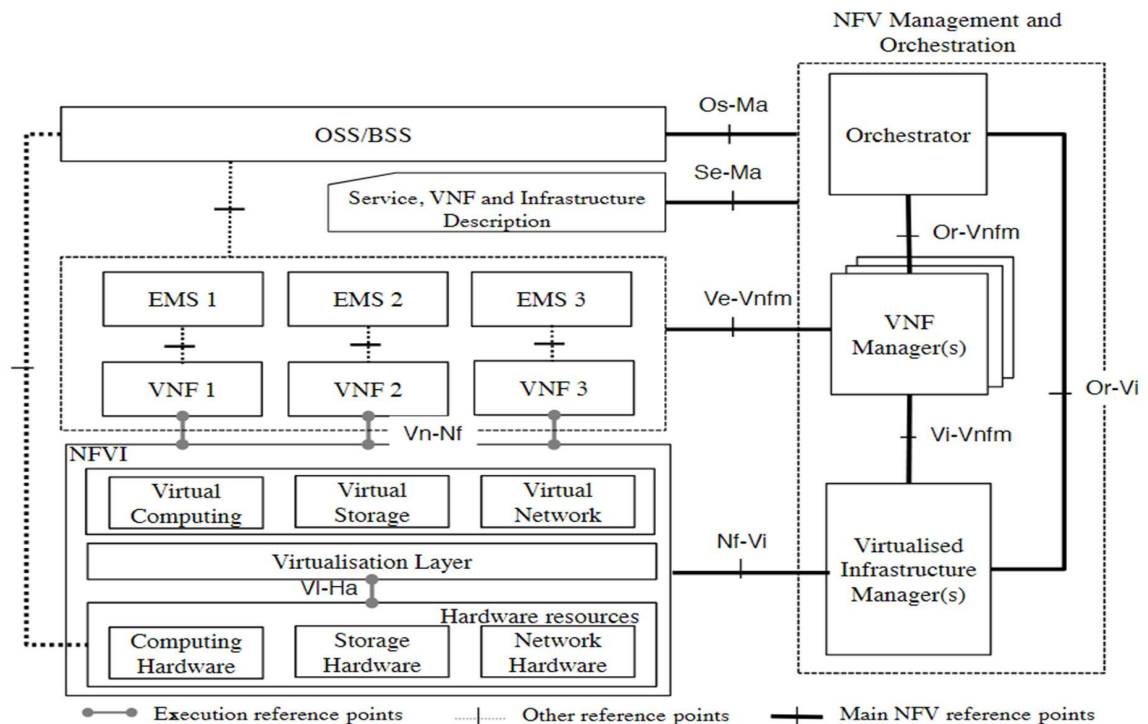


图 1. 高级 NFV 框架

VNFs（虚拟网络功能）：VNFs 是代表在 NFVI 上实现传统网络功能的软件包。分组数据网络网关（PGW）、住宅网关、防火墙以及其他内部组件（VNFCs）可以组成一个单一的 VNF。另一方面，一个 VNF 可能只有一个组件，尽管一个单一的 VNF 可能会在多个 VMs 中部署和分散。此外，网络图是 VNF 服务的集合，它们一起为客户提供预期的服务，即它们可能基于可用的 VNFs 创建一个虚拟网络。电信公司的虚拟网络服务通常由许多根据客户需求定制的 VNFs 组成。

NFV 管理和编排（MANO）负责管理和编排 VNF 生命周期内所有特定于虚拟化的操作，从将多个服务合并为一个 VNF 包到根据请求将该服务映射到消费者。MANO 还管理可能发生的任何 VNF 故障，以及维护服务中每个 VNF 的状态信息。此外，MANO 负责在构成网络图的各个 VNF 之间建立通信。MANO 由三个主要功能块组成：

- **虚拟基础设施管理器（VIM）：**负责管理和控制 VNFs 与 NFVI 资源的交互。VIM 执行资源管理功能，如对软件进行库存管理以及资源的管理和编排。VIM 还负责收集和记录信息以检查故障，以及为容量规划、性能监测和性能优化收集信息。
- **VNF 管理器（VNFM）：**负责通过元素管理系统（EMS）管理和监测 VNF，包括对 VNF 进行缩放、改变操作以及添加新资源，并将 VNF 的状态传达给构成 NFV 架构的其他功能块。
- **编排器：**提供设置基于云的服务和应用所需的必要资源和网络，包括使用不同的虚拟化软件以及硬件。

2.2 模式和参考架构

要模式是特定上下文中反复出现问题的解决方案。模式因目的和解决的问题而异。安全模式用于通过描述控制威胁、修补漏洞和提供安全属性的方法来构建安全系统。设计和架构模式用于构建灵活和可扩展的系统。误用模式用于从攻击者的角度描述攻击是如何进行的。它们还定义了攻击发生的环境、作为对策需要哪些安全机制来阻止它以及一旦攻击发生可以在哪里找到取证信息来追踪它。

参考架构（RA）是一种用于分析、设计和理解复杂系统的通用抽象软件架构。RA 包括一组利益相关者、用例以及一个概述系统组件、它们的功能及其相互依赖关系的图表，但不包括实现细节。安全机制可以在 RA 内的适当位置纳入，以管理已识别的威胁，从而定义一个安全参考架构。

模式是最佳实践的抽象；它们不提出新的解决方案。因此，模式论文不包括实现或实验，模式和参考架构的原创性在于与现有系统相关的模型的完整性和准确性；其理念是将这些知识和经验用于新设计并评估现有设计。SRA 在意图和用途上相似，并且以类似的方式进行验证。

3 NFV 的安全参考架构

在 [9] 中我们调查了一些威胁及其可能的误用。威胁及其影响可以用误用模式来描述。误用模式从攻击者的角度描述攻击是如何进行的；它们定义了攻击发生的环境、需要哪些安全机制作为对策来阻止它以及一旦攻击发生如何找到取证信息来追踪它。我们在这里展示 NFV 中三种威胁的三种误用模式：特权提升、虚拟机逃逸和拒绝服务。这些误用模式被认为是构建安全参考架构（SRA）的第一步，因为它们展示了哪些防御（安全模式）可以防止攻击。如图 2 所示的模式图中，一个误用模式定义了对 NFV RA 的

威胁，并且可以通过一个安全模式来缓解。我们可以通过向 RA 添加安全模式来控制所有已识别的威胁，从而获得一个 SRA。换句话说，一个 SRA 是一个 RA，其中所有已识别的威胁都通过添加安全模式得到了控制。如果有许多威胁，进行风险分析是有用的，其中评估威胁发生的概率和影响；然而，标准的风险分析方法可以使用，我们在这里不讨论这个阶段。首先，实际的威胁选择取决于具体的应用。

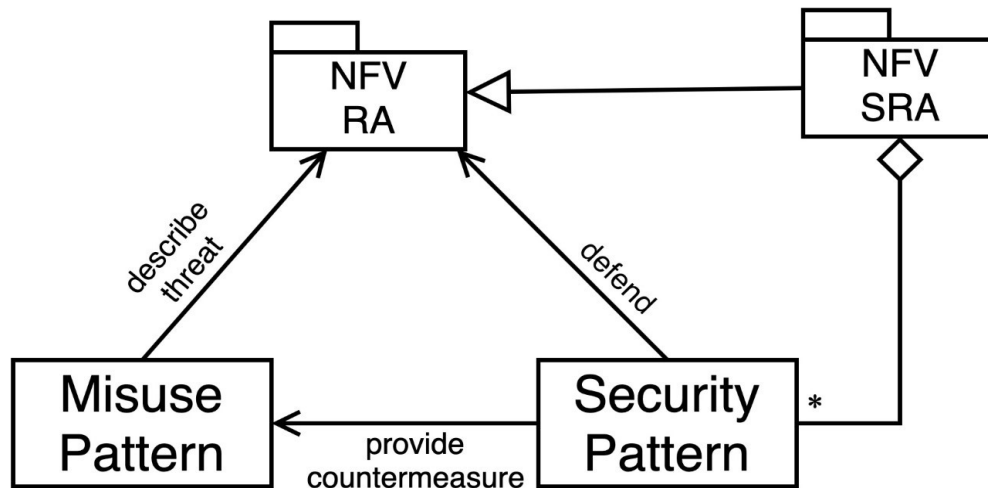


图 2. NFV 安全参考架构 (SRA) 的模式图

3.1 通过误用活动发现威胁

协同我们现在呈现一个 NFV 用例，以展示我们如何在系统中发现威胁。用例活动图展示了执行用例所涉及的活动。每个活动都可以创建或使用可能受到攻击的资产；虚线圆角矩形代表威胁，虚线代表与误用相关的控制流。我们通过对用例活动进行系统分析来识别 NFV 的威胁，考虑每个用例中的每个活动。在列举威胁之后，我们选择适当的安全政策来缓解这些威胁；我们还将威胁与其来源连接起来，以表明它们是来自内部人员还是外部人员攻击者。由于所有用例代表了与系统的所有交互，并且我们检查了它们的所有活动，我们几乎可以找到所有威胁，这意味着如果我们能够消除它们，系统在实际意义上就是安全的。对用例“请求修改 VNF”和“使用网络”的威胁分析。

NFV 的一个主要特征是与传统网络相比的灵活性。在 NFV 中，消费者 - 运营商 (Con - Ops) 可以根据自己的需要随时请求修改他们正在使用的资源，无论是扩大还是缩小网络，这使得这个用例成为 NFV 生命周期的基本用例之一。NFV 中修改资源的过程仅仅是通过从 Con - Op 向 NFVP 操作员发送一个请求来完成的，NFVP 操作员反过来改变网络以匹配消费者的需求，并将修改确认发送回 Con - Op。然而，在这个过程中，可能会出现几种威胁。例如，Con - Op 可能是一个冒名顶替者，他破坏消费者正在使用的 VNF 以发送一个恶意的 hypercall，这导致控制 hypervisor，从而导致几种误用，如提升攻击者 VM 的特权，或让 VM 从 hypervisor 控制中逃逸。图 3 展示了请求修改 VNF (UC13) 和使用网络 (UC20) 用例的活动图，显示了一些可能的误用。

通过对图 3 活动图中事件流的系统分析，我们已经识别了几种可能影响网络服务

的威胁。表 1 展示了基于两个方面对前面活动图中每个动作的分析：主要安全属性（保密性（CO）、完整性（IN）、可用性（AV）、问责性（AC））以及威胁来源（授权内部人员（AIn）、未授权内部人员（UIn）、外部人员（Out））。

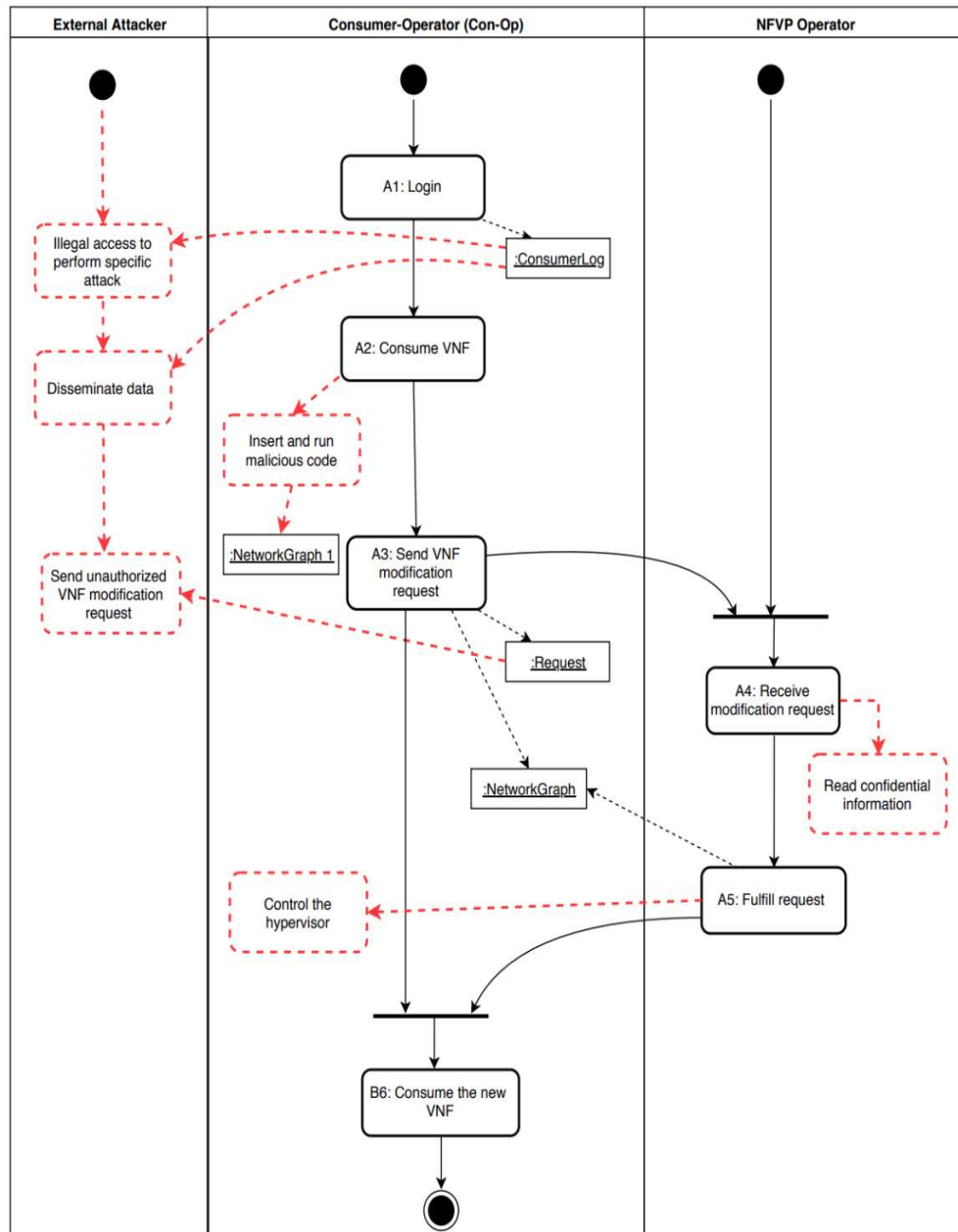


图 3. UC13 “请求修改 VNF” 和 UC20 “使用网络” 的活动图

表 1 误用活动分析

Actor	Action	Threat Number	Sec. Attr. CO/IN/AV/AC	Source AIn/UIn/Out	Description
Con-Op	A1. Login	T1	CO	Out	An external attacker illegally accesses the system to perform specific attacks, such as modify the network
		T2	CO	Out	An external attacker disseminates Con-Op's data.
	A2. Consume VNF	T3	IN	AIn	The Con-Op inserts and runs malicious codes within the VNF.
	A3. Send VNF modification request	T4	IN	Out	An external attacker modifies the Con-Op requests while in transit.
		T5	AV	AIn/Out	The Con-Op overwhelms the system with requests to make the service unavailable (DoS).

表 1 续

Actor	Action	Threat Number	Sec. Attr. CO/IN/AV/AC	Source AIn/UIn/Out	Description
NFVP Operator	A4. Receive modification request	T6	CO	AIn/UIn	The NFVP Operator collects confidential information.
	A5. Fulfill request	T7	CO/IN	AIn	The Con-Op compromises the hypervisor in unauthorized manner, which results to accomplish the attacker's malicious goals, such as controlling the hypervisor, modify VM privilege, or VM escape.

在分析用例活动并发现不同的误用之后，我们可以推荐一些适当的缓解机制，这些机制可以被实施并包含在系统中，以缓解这些误用。表 2 展示了已识别的误用及其缓解机制。认证器被设计用于阻止对系统的未授权访问，这证明这种行为是可以被阻止的。

表 2 威胁列表及其缓解措施

Threat Number	Description	Defense Mechanism
T1	An external attacker illegally accesses the system to perform specific attacks, such as modify the network.	Authenticator
T2	An external attacker disseminates Con-Op's data.	Security logger/auditor
T3	The Con-Op inserts and runs malicious codes within the VNF.	Filter module
T4	An external attacker modifies the Con-Op requests while in transit.	Secure channel
T5	The Con-Op overwhelms the system with requests to make the service unavailable (DoS).	CVAS, traffic filtering and detection mechanisms
T6	The NFVP operator collects confidential information.	Security logger/auditor
T7	The Con-Op compromises the hypervisor in unauthorized manner, which accomplishes the attacker's malicious goals, such as controlling the hypervisor, modifying VM privilege, or VM escape.	Patching the hypervisor

3.2 基于特权提升的误用模式

意图

VMs 由 hypervisor 创建和管理, hypervisor 有权满足它们的 hypercall 请求并确保它们之间的隔离。攻击者（可能是消费者）可能提升其 VM 的特权, 从而允许他执行 hypervisor 特权操作, 这可能导致几种误用, 如未经授权访问硬件、创建恶意 VMs 以及终止共存的 VMs。

问题

为了进行这些误用, 攻击者在他的 VNF 中运行一个恶意应用程序, 该应用程序向 hypervisor 发送一个恶意 hypercall。这种误用可以通过利用以下漏洞来实现:

- VMs 可以向 hypervisor 发送任何类型的 hypercall, 无论是合法的还是恶意的
- Hypercall 是用于处理和资源访问的低级内核请求, 区分合法与恶意 hypercall 可能具有挑战性。
- 因为网络服务托管在一个可共享的环境中, 如果一个 VNF 被破坏, 其他共存的 VNFs 可能会受到影响。
- 新的攻击（如面向返回的编程（ROP）攻击）的出现, 允许攻击者改变 hypervisor 中的 VM 特权级别。

解决方案

如果攻击者有一个有效的账户, 他将能够请求网络服务。然后, 在他的 VNF 之上运行的一个应用程序可以通过 hypercall 向 hypervisor 发送处理和资源请求, 从而允许攻击者利用该应用程序运行恶意代码。这些 hypercall 使用 hypervisor 文件进行处理。利用 CVE - 2011 - 1583 漏洞（该漏洞授予攻击者对 hypervisor 的控制并修改他们的 VM 特权级别）是攻击者提升其 VM 特权级别的一种方式。另一种方法是使用一个恶意 hypercall, 如在 [23] 中开发并应用于 Xen hypervisor 的那个, 我们稍后将展示。

每个 VM 都有一个存储在 hypervisor 中的域结构; 这个结构包含关于 VM 的基本信息, 如 domain_id（VM 的标识号）、is_privilege（每个 VM 的特权级别）以及 next_in_list（用于按 domain_id 升序将这些域结构链接在一起）。例如, Xen hypervisor 创建一个父 VM（domain 0）, 它通过遍历 dom0 创建子 VMs（domain 1, domain 2, 等）, 通过知道 dom1 的 domain_id 可以识别 dom1 的域结构。

误用开始于一个恶意 hypercall 被传递到 hypervisor, 其栈缓冲区溢出, 允许恶意应用程序访问 hypervisor 地址空间并随后发起一个面向返回的编程（ROP）攻击。ROP 是一种改变 hypervisor 内存空间中现有代码而不是写入新代码的攻击。ROP 攻击的结果是通过将 is_privilege 值从 0 变为 1 来提升攻击者 VM 的特权。成功的攻击允许攻击者执行 hypervisor 操作, 如终止虚拟机, 导致拒绝服务, 并获得对硬件资源的未经授权访问, 从而破坏整个虚拟化环境。这种攻击场景应用于云计算环境, NFV 能够阻止

与恶意 VNF 共存的 VNFs，甚至创建更多恶意 VNFs。

结构

图 4 展示了 NFV 中基于特权提升的误用的类图。通过门户，消费者连接到 NFV 服务。他也可以使用 API 来访问 VNF 功能。VIM 是一个 MANO 软件单元，负责管理 NFV 基础设施，包括 hypervisor。hypervisor 管理提供网络服务所需的硬件资源，并调解对它们的访问。它还控制 VMI 存储库，该存储库存储 VM 图像（VMIs），创建 VMs，将它们分配给消费者账户，并管理提供网络服务所需的硬件资源。一个 VMI 用于创建 VMs。hypervisor 在 VM 启动后为其分配硬件资源。许多 VMs 可以为每个消费者分配一组 VNFs。Hypercalls 是虚拟机发送给 hypervisor 的系统调用，hypervisor 在硬件中执行它们。

动态

误用案例（MC）1：基于攻击者 VM 特权提升的对硬件的未授权访问（图 5）。

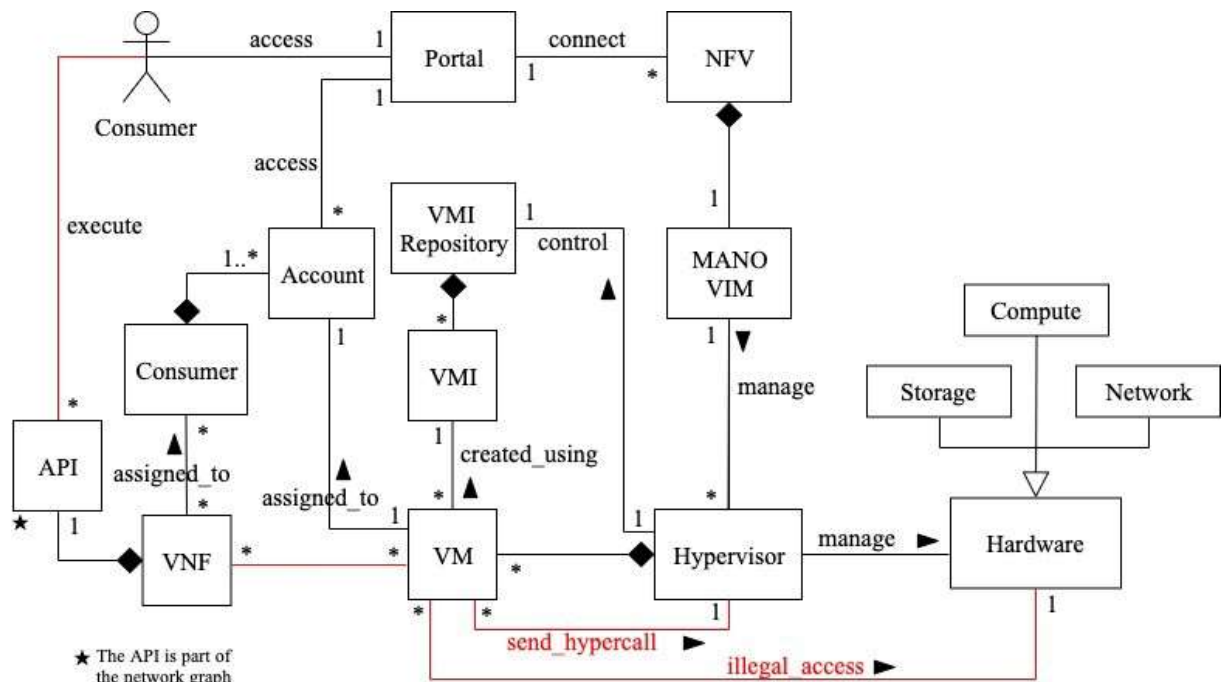


图 4. NFV 中基于特权提升的误用的类图

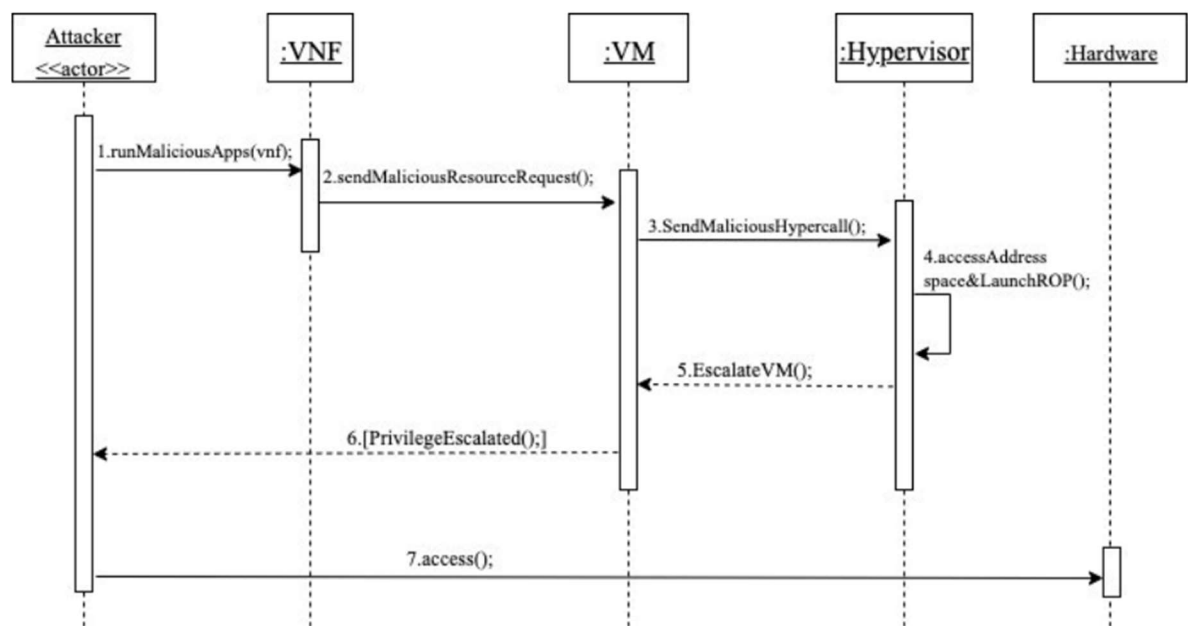


图 5. 基于攻击者 VM 特权提升的对硬件资源的未授权访问的 MC1 顺序图

总结：攻击者（是一个消费者）在他的虚拟网络功能（VNF）中运行一个恶意应用程序，以便向虚拟机监控程序（hypervisor）发送一个恶意的超级调用（hypercall）。该应用程序访问 hypervisor 地址空间并发起一个面向返回的编程（ROP）攻击，将攻击者的虚拟机（VM）的 `is_privilege` 值从 0 修改为 1（从无特权变为有特权）。这种特权提升的成功使得攻击者能够非法访问硬件资源并获取机密数据。

角色：攻击者

前提条件：攻击者拥有一个有效的账户和活动的网络服务。

描述：

1. 攻击者首先在他的 VNF 中运行一个恶意应用程序。
2. 使用该恶意应用程序，一个恶意的资源请求作为 hypercall 被发送。
3. 恶意的 hypercall 通过虚拟机转发给 hypervisor。
4. hypervisor 接收到恶意的 hypercall 请求并执行它。在这种情况下，恶意应用程序访问 hypervisor 地址空间并发起一个 ROP 攻击。ROP 攻击的结果是通过将 `is_privilege` 值从 0 变为 1 来提升攻击者的 VM 的特权。
5. hypervisor 提升 VM 的特权级别。
6. 攻击者被通知 VM 已成功提升特权。
7. 攻击者现在能够非法访问硬件资源。

后置条件：攻击者控制 hypervisor，并能够直接访问硬件资源，从而可以执行恶意操作。

后果

一次成功的攻击会导致以下后果：

1. 攻击者能够破坏系统及其数据，因为他能够非法访问硬件资源。
2. 攻击者可以完全破坏网络服务（拒绝服务，DoS），阻止 NFV 消费者使用该服务。
3. 提升攻击者的 VM 的特权使他能够执行 hypervisor 操作，例如直接访问硬件资源以及危及系统服务器，创建、启动、停止、迁移和终止受害者的 VM。

- 攻击者可能是网络服务市场的竞争对手，并旨在损害 NFV 提供者的声誉，因为他们的服务已被破坏并且似乎存在安全问题。

对策

VM 特权提升可以通过以下对策缓解：

- hypervisor 供应商修补系统漏洞；因此，如果攻击者利用导致特权提升的漏洞，可以使用供应商在 [25] 中的补丁来缓解攻击（该漏洞在 [22] 中有描述）。
- 使用一些缓解 ROP 攻击的安全工具，如 G - Free [26]、Hyper - Crop [27]、HyperVerify [28]、ROPecker [29]，以及 [30] 中提出的硬件虚拟化机制。
- 使用包括 hypercalls 控制和认证 hypercalls 的安全方案，这些有助于验证 hypercalls 的真实性 [31]。

3.3 通过虚拟机逃逸破坏虚拟机的误用模式

意图

hypervisor 创建和管理 VMs 并确保它们之间的隔离。攻击者（可能是消费者）旨在破坏这种隔离，通过执行任意代码使 VM 从 hypervisor 控制中逃逸并进行可能的误用。

问题

攻击者如何违反 hypervisor 在其 VMs 和硬件之间提供的隔离，从而实现 VM 逃逸？这种攻击可以通过利用以下漏洞来实现：

- hypervisor 是一个包含各种组件（如驱动程序、调度器和 hypercalls 表）的软件。由于其设计复杂性，hypervisor 的安全性难以维护。
- hypervisor 是虚拟化环境中最关键的组件之一，因为它调解虚拟化实例和硬件。因此，一个错误的 hypervisor 配置可能导致攻击者可以利用的一些漏洞，如 VM 逃逸。
- VMs 通过 hypervisor 与主机操作系统相互连接；如果缺乏隔离，攻击者将能够侵入主机操作系统。
- 许多导致 VM 逃逸的漏洞的存在证明了虚拟化环境不够健壮，即使这些漏洞已经被修补。
- hypervisors 从 VMs 接收和发送 hypercalls。这些 hypercalls 是用于基本处理和资源访问的低级请求，很难区分合法和恶意 hypercalls；因此，攻击者可以利用这一点向 hypervisor 发送恶意请求。
- 网络服务托管在一个共享环境中；如果一个 VNF 被破坏，可能会影响其他共存的 VNFs。

解决方案

如果攻击者有一个有效的账户，在一个正在运行的服务中，他可以在其 VNF 之上运行的应用程序中运行恶意程序，发送特制的网络数据包，利用堆溢出控制 hypervisor，实现 VM 逃逸。通常，特制数据包用于对网络进行测试；然而，攻击者可能创建数据

包来进行攻击并利用网络中的漏洞。在一个实际场景中，这些数据包通过 `hypercalls` 发送。结果，攻击者将能够在 `hypervisor` 上执行任意代码，以获得对主机操作系统的访问，从而使 `VM` 从 `hypervisor` 控制中逃逸。此外，逃逸的 `VM` 可以直接与 `hypervisor` 接口，绕过任何隔离，并将能够访问其他与他的 `VM` 共存的受害者的 `VMs`。这允许攻击者访问每个受害者的虚拟机并进行各种恶意操作，如传播机密信息、停止 `hypervisor` 和在其上运行的 `VMs` 等。

结构

如图 6 所示，为了请求 NFV 服务，消费者使用门户连接到 NFV 服务。他也可以使用 API 来访问网络功能。VIM 是一个 MANO 软件单元，负责管理 NFV 基础设施，包括 hypervisor。hypervisor 控制和调解对 VMI 存储库的访问，该存储库存储 VM 图像（VMIs），构建 VMs，将它们分配给用户账户，并管理提供网络服务所需的硬件资源。一个 VMI 用于构建每个 VM。hypervisor 在 VM 启动后为其分配硬件资源。VMs 可以包含大量分配给每个消费者的 VNFs，或者一个 VNF 可以在主机中使用恶意操作。在上述攻击场景中，NFV 消费者（攻击者）运行几个 VMs。Hypercalls 是虚拟机发送给 hypervisor 的系统调用，hypervisor 执行这些调用，允许他获得对主机操作系统文件的访问。

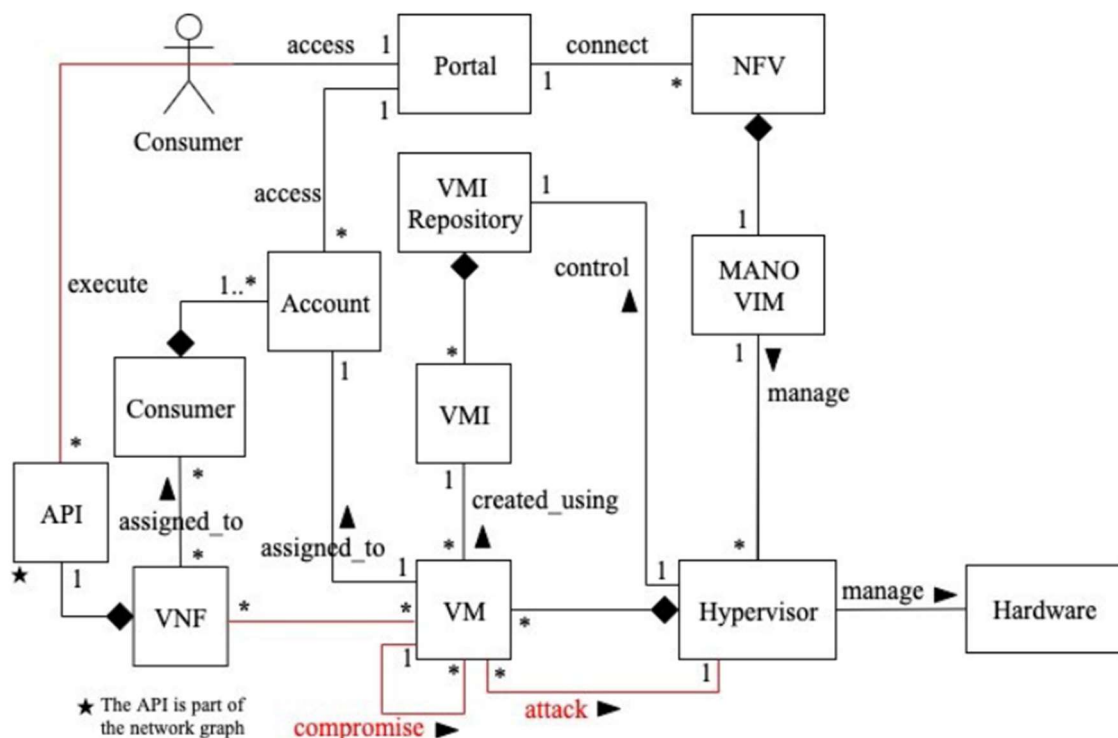


图 6. NFV 中通过虚拟机逃逸破坏虚拟机的类图

动态

MC2: 通过 VM 逃逸破坏受害者的 VMs (图 7)。

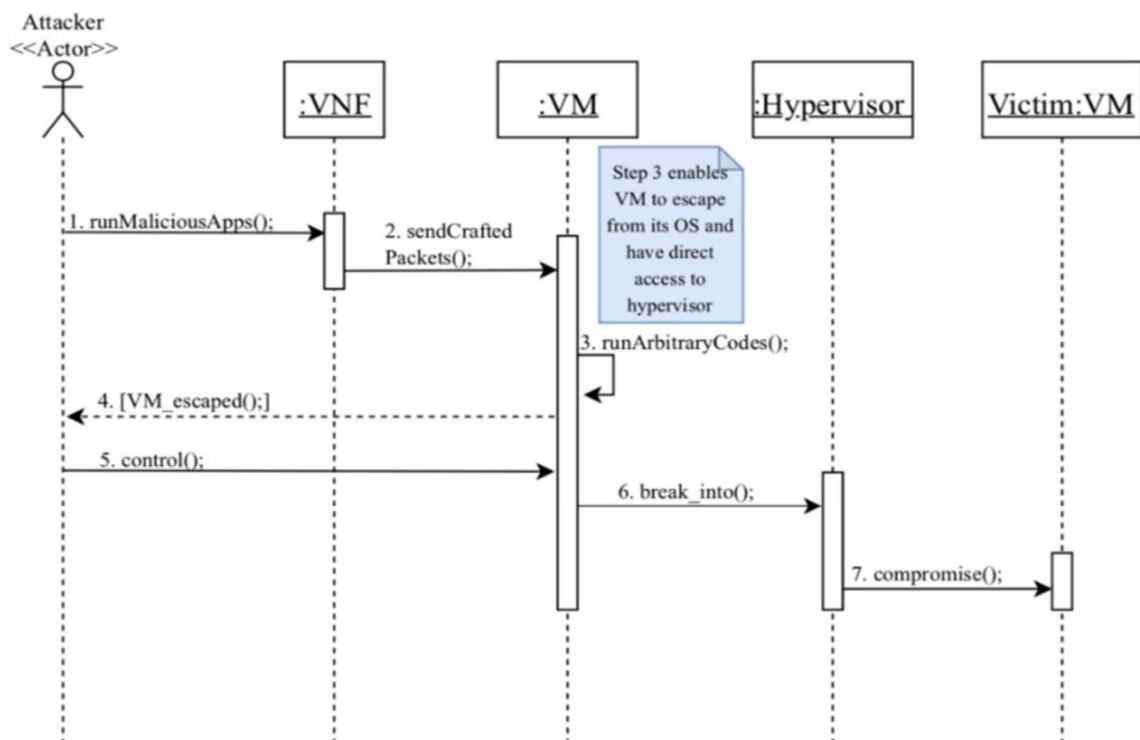


图 7. MC2 的顺序图：通过虚拟机逃逸破坏受害者的虚拟机

总结：虚拟机逃逸攻击由攻击者（是一个消费者）执行。

角色：攻击者

前提条件：攻击者拥有一个有效的账户和活动的网络服务。

描述：

1. 攻击者首先在他的虚拟网络功能（VNF）中运行一个恶意应用程序，并通过获得对虚拟机操作系统的访问来破坏它。
2. 使用被破坏的 VNF，攻击者向虚拟机发送一个特制的网络数据包以利用堆溢出。
3. 在虚拟机监控程序上执行任意代码导致虚拟机逃逸。这些代码使攻击者能够访问主机操作系统。
4. 攻击者被通知虚拟机已成功从虚拟机监控程序的控制中逃逸。
5. 因此，攻击者现在可以控制虚拟机。
6. 攻击者可以通过被控制的虚拟机读写虚拟机监控程序的数据。
7. 现在，攻击者能够使用被控制的虚拟机监控程序破坏受害者的虚拟机。

后置条件：攻击者破坏共存的受害者的虚拟机，这可能导致信息的多种误用。

3.4 NFV 中的分布式拒绝服务攻击误用模式

意图

攻击者意图通过从域名服务器（DNS）发送大量请求耗尽网络资源，影响服务可用性。

问题

攻击者如何通过向目标（消费者的一个网络服务）发送大量 DNS 请求消耗其大部分资源（如带宽），从而实现 DDoS 攻击？

这种攻击可以通过利用以下漏洞来实现：

- NFV 是一项新兴技术，其安全基础设施在实际环境中尚未得到充分测试，这增加了漏洞可能导致包括拒绝服务在内的多种威胁的可能性。
- 采用 NFV 服务的紧迫性可能使网络功能虚拟化提供商（NFVPs）更关注利润，而没有强化其基础设施（包括 DNS 服务器配置）的安全性。
- 网络服务托管在运行在虚拟机之上的共享环境中；如果由于配置错误、恶意软件感染或利用在其上运行的旧版本软件中的漏洞而导致虚拟网络功能（VNF）被破坏，大量流量可以从被破坏的 VNF 生成并发送到在同一虚拟机监控程序上甚至不同虚拟机监控程序上运行的其他共存 VNF，或者发送到 DNS。
- 与传统架构相比，NFV 环境为网络功能提供了更高程度的灵活性和配置可能性；因此，有更多的方法可以错误配置网络功能，这增加了攻击面并为破坏系统开辟了新途径。
- NFV 环境的弹性使网络资源能够快速扩展或收缩。在 DNS 放大分布式拒绝服务（DDoS）攻击的情况下，当由于流量负载而创建多个虚拟 DNS（vDNS）并将向受害者产生大量 DNS 回复时，攻击者可以利用此属性来放大攻击。这种情况在 NFV 环境中是可能的，我们将在后面的部分中进行演示。
- 域名系统，特别是公共 DNS，被设计为响应任何请求，在这种情况下攻击者可以将一些 DNS 请求转换为更大的有效载荷。攻击者可以利用这种放大效应来发动 DDoS 攻击。

解决方案

当攻击者使用伪造的 IP 地址向网络资源发送大量 DNS 请求时，攻击是可能的。首先，我们假设攻击者有一个被感染设备的僵尸网络和受害者的 IP 地址列表。攻击者伪造受害者机器的 IP 地址，并使用由命令与控制服务器控制的僵尸网络，发送大量恶意 DNS 请求（UDP 数据包）。这些请求被发送到一个 VNF（一个 vDNS）。编排器意识到 vDNS 上的流量负载高于正常阈值，然后 hypervisor 启动新 VMs 以扩展额外的 vDNSs 来容纳更多请求。NFV 的弹性和可扩展性将使多个 vDNS 递归地响应受害者，并实际上会收到放大的 DNS 响应，这最终可能导致受害者的网络服务器服务中断。

结构

如图 8 所示，是 NFV 中分布式拒绝服务攻击的类图，显示了被此攻击破坏的单元。命令与控制服务器（CC）是一个由攻击者控制的集中管理平台，用于编排攻击。僵尸网络是一个攻击机器的网络，攻击者使用它来发送大量包含伪造 IP 地址与受害者 IP 地址匹配的恶意 DNS 请求。消费者使用他们的 API 访问 VNF 功能。vDNS 是

VNF 功能之一。hypervisor 控制 VMI 存储库，该存储库存储 VM 图像（VMIs），创建 VMs，管理 NFVI 资源以提供网络服务。每个 VM 是用一个 VMI 创建的，VMs 可以包含几个 VNFs。一旦 VM 启动，hypervisor 为其分配资源。MANO 是一个管理和编排（MANO）单元，有几个角色，如通过 VIM 向 hypervisor 报告状态信息，以及通过 VNFM 监测 VNF。

动态

MC3: NFV 中使用 DNS 放大攻击的分布式拒绝服务攻击（图 9）。攻击者使用伪造的 IP 地址向 vDNSs 发送大量 DNS 请求，vDNSs 反过来向受害者发送放大的响应，导致服务不可用或中断。

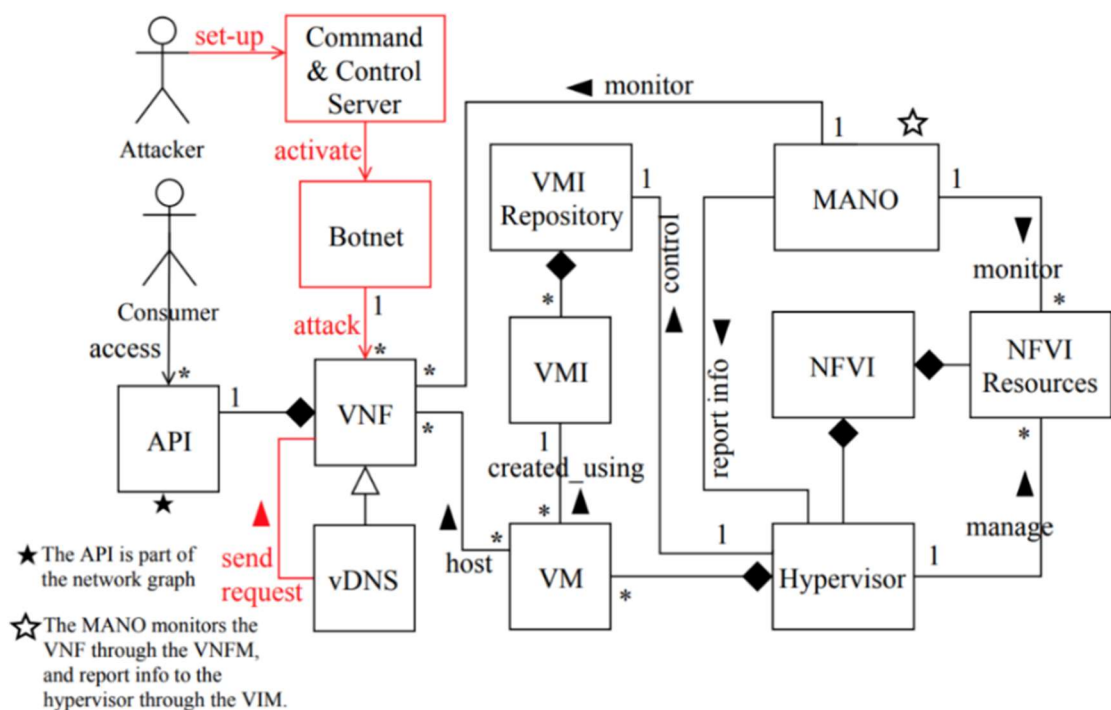


图 8. NFV 中分布式拒绝服务（DDoS）攻击的类图

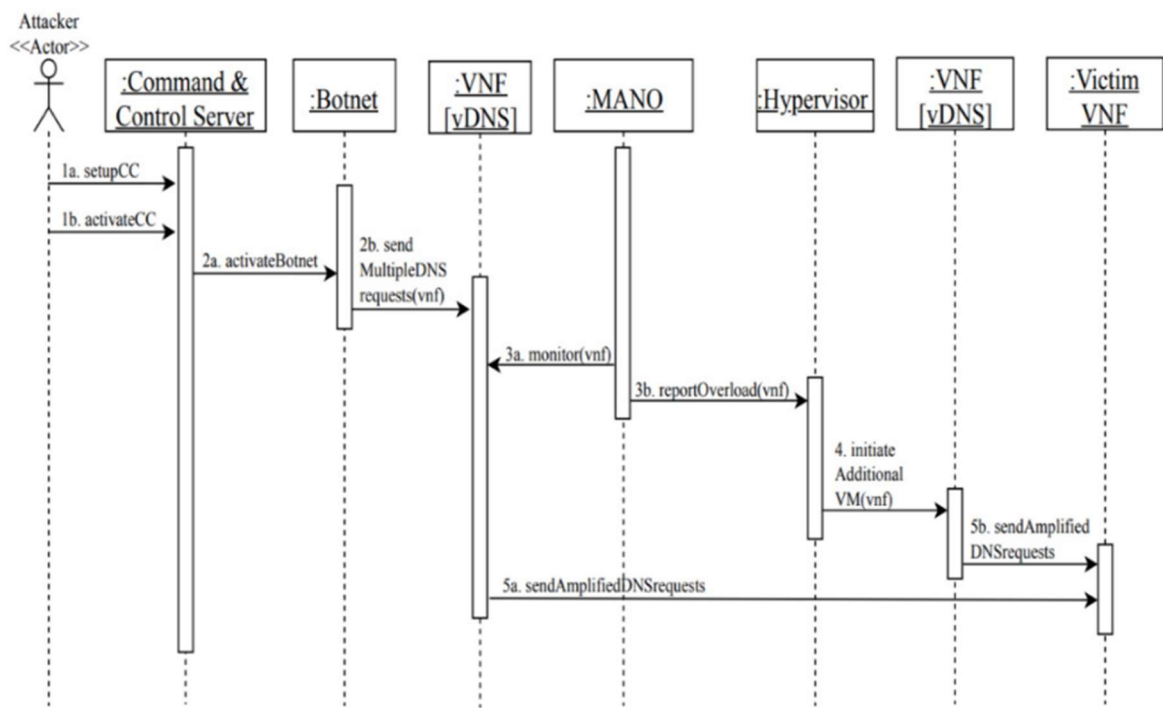


图 9. NFV 中使用 DNS 放大攻击的分布式拒绝服务（DDoS）攻击的顺序图

后果

角色：攻击者。

前提条件：攻击者控制着一个由受感染设备组成的僵尸网络以及受害者的 IP 地址列表。

描述：

1. 攻击者首先设置命令与控制服务器（CC）并激活它。
2. 通过命令与控制服务器，攻击者激活僵尸网络并向僵尸网络发送攻击命令，以向虚拟虚拟域名系统（vVDNS）发起大量 DNS 请求。
3. 与此同时，网络功能虚拟化管理与编排（MANO）正在监控虚拟网络功能（VNF），并意识到流量负载高于正常阈值，并将其报告给虚拟机监控程序。
4. 作为对 vDNS 上高流量负载的响应，虚拟机监控程序启动额外的虚拟机以扩展额外的 vDNS，以适应更多请求。
5. 相应地，放大的 DNS 请求从 vDNS 递归地发送到受害者的网络服务器，这导致服务不可用或中断。

后置条件：受害者的虚拟机将被破坏或变得不可用。

3.5 保护 NFV 服务

虚拟网络功能（VNFs）被认为是网络功能虚拟化（NFV）系统的核心，因此它们是攻击者的高价值目标，攻击者意图破坏网络。现在我们考虑一些安全机制来保护网络

服务免受表 2 中确定的误用。图 10 展示了在添加一些安全机制（以蓝色显示）后的部分安全参考架构（SRA），以保护其免受 MC1 和 MC2 的攻击。该 SRA 基于两个用例：UC13（修改 VNF）和 UC20（使用 VNF）。认证器 [5] 防止外部攻击者访问系统，这可以阻止威胁 T1。安全日志记录器 [5] 在 T2 和 T6 中用于记录和跟踪网络资源内的任何活动，并用于进行取证的安全审计员。过滤器扫描 VNF 以去除恶意代码，如错误大小参数、错误类型参数或错误操作，这可以阻止威胁 T3。安全通道 [10] 缓解 T4，为网络服务提供完整性和保密性。基于角色的访问控制（RBAC）[10] 用于根据预定义的权限控制对虚拟资源的访问，并可用于缓解 T6。受控虚拟地址空间（CVAS）模式 [10] 用于限制和控制进程对其虚拟地址空间特定区域的访问；这可用于缓解 T5，并防止特权提升。

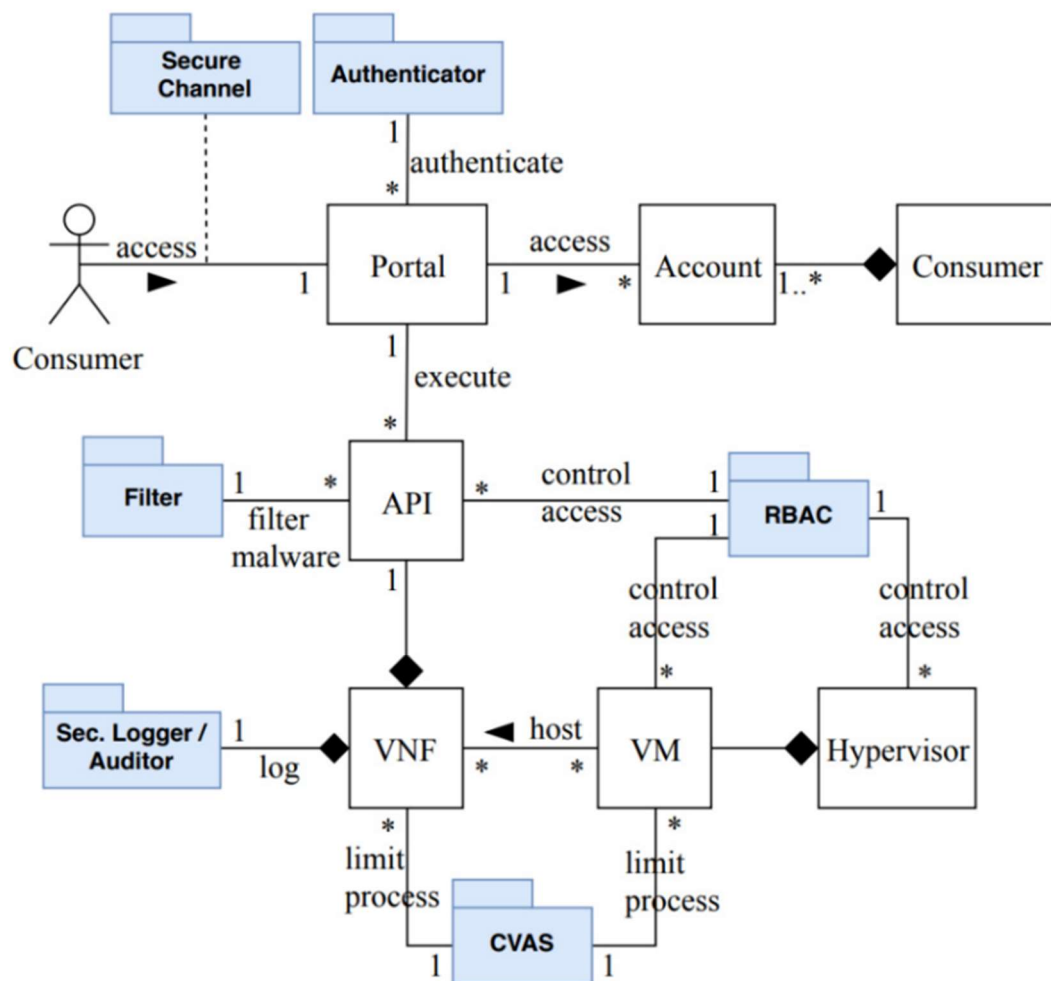


图 10. NFV 的部分安全参考架构

3.5.1. NFV 安全参考架构的安全评估

在前面的部分中，我们分析了 UC13 和 UC20 的用例活动，并确定了每个活动中可能的误用。然后，我们应用了可以抵御这些误用的缓解机制。现在，我们需要评估我

们的部分安全参考架构，以检查它是否涵盖了已确定的误用。我们将使用前面描述的误用模式来测试我们的模型。在图 5 中，我们展示了攻击者（Con-Op）如何在虚拟网络功能（VNF）上插入并运行恶意代码，以便向虚拟机监控程序发送恶意请求。

攻击者可以向虚拟机监控程序发送恶意请求，导致修改承载攻击者虚拟网络功能的虚拟机的特权，或者让虚拟机从虚拟机监控程序的控制中逃逸，如图 7 所示。因此，我们使用图 11 的顺序图来展示安全机制如何阻止在 MC1 和 MC2 中确定的威胁。在图 11 中，可以看到攻击者（Con-Op）在登录期间将被认证，以确保只有合法用户访问 NFV 系统。即使攻击者有一个有效的账户，他在虚拟网络功能上插入恶意代码的尝试也将被过滤器处理，过滤器会扫描并移除恶意代码。类似地，我们可以展示其他威胁可以被相应的安全模式处理。

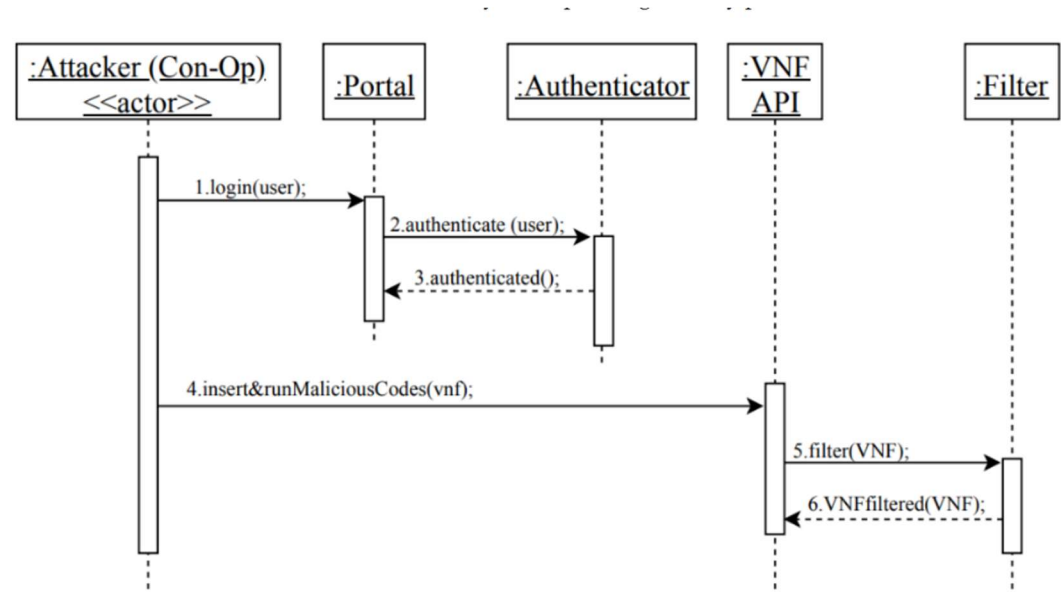


图 11. NFV 中安全使用网络的顺序图

如上文所示，从误用模式中我们可以找到能够阻止攻击者误用的安全模式。安全模式的定义旨在控制特定攻击。我们在此处使用的所有模式都已在模式会议上展示并在实践中得到验证，并在 [10] 中进行了编目。如果在参考架构中识别到威胁，并且该威胁可以由一种模式处理，我们认为如果该模式在架构中实例化，它将能够阻止相应的攻击。对所有用例的分析将使我们确信所有重要威胁都已被识别。图 11 展示了插入安全模式如何阻止来自两个误用用例的可能误用。

4 SRAs 的验证

建筑模型已被证明是呈现和理解复杂系统的有力机制。然而，SRA 是一个抽象模型，不能使用传统的实验或测试方法评估其性能、可靠性或安全性。构建一个原型是一个复杂的工作；此外，如果原型不安全，它不能否定 SRA，因为原型可能有实现缺陷。另一方面，可以使用其他标准来验证 SRA 和安全模式。第 3.5.1 节中展示的安全评估

是这种验证的一个方面，因为我们可以通过论证表明我们的模型是安全的。我们可以通过将模型与其他商业 NFV 系统的模型进行比较来进一步验证抽象模型；我们在这里明确地将我们的 NFV SRA 的基本组件与这些系统的元素进行比较；记住，一些这些系统使用额外的组件来支持它们的功能，这些组件对 NFV 基本服务不是必需的。这提供了一个完整性验证。

我们的安全参考架构是通过对威胁进行分析而演绎得出的。目前还没有工业公司为其 NFV 产品发布安全参考架构。大多数 NFV 项目报告都集中在 NFV 的部署上，而没有描述保护其架构的方法。这可能是因为 NFV 范式在网络行业中仍然是一个较新的概念，确定其安全要求需要时间。因此，我们的安全参考架构为行业提供了一个指导方针，展示了他们在架构中应该包含哪些安全防御措施。我们仍然可以将我们的安全参考架构与一些框架进行比较，并且通过将其组件和安全措施与这些框架进行比较来验证我们安全参考架构的完整性和准确性。

我们将我们的模型与 ETSI 安全框架、云安全联盟(CSA)安全框架和 Red Hat NFV 平台进行了比较。我们比较了 VNF、VM、hypervisor、API、VIM 等主要组件以及认证器、过滤器、安全记录器 / 审计器、RBAC、CVAS、安全通道等安全机制。结果表明我们的 SRA 在主要组件和安全机制上与这些框架有较好的匹配度，验证了 SRA 的准确性，但也指出 SRA 是部分的，未涵盖 NFV 系统的所有安全需求，但能缓解部分威胁。

表 3 展示了我们的安全参考架构与所选框架之间的比较。我们将我们安全参考架构的所有主要组件及其安全机制列为列，所选的 NFV 安全框架以行的形式呈现。我们安全参考架构的每个组件都与安全框架进行匹配，如果在特定安全框架中找到该组件，则放置一个标记。

表 3. NFV 安全参考架构的验证。

Frameworks Components	VNF	VM	Hypervisor	API	VIM	Authenticator	Filter	Sec. Log/Auditor	RBAC	CVAS	Sec. Channel
NFV SRA	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
ETSI Security Framework	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
CSA Security Framework	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Red Hat Platform	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓

我们的安全参考架构包含从参考架构中衍生出的几个组件，这些组件对于确保网络服务的可操作性是必要的，并且它们应该在每个 NFV 框架中都能找到。如前所述，我们的安全参考架构处于进行阶段，并未涵盖 NFV 系统所需的所有安全措施；然而，它确实减轻了第 3 节中描述的威胁。

如图 10 所示，安全参考架构的架构组件包括虚拟网络功能(VNF)、虚拟机(VM)、虚拟机监控程序、应用程序编程接口 (API) 和虚拟基础设施管理器 (VIM)；我们排除了门户、账户和客户组件。如表 3 所示，ETSI、CSA 和 Red Hat 框架在其 NFV 安

全框架中包含这些组件。可以推断出这些组件在每个 NFV 平台中都是确保 NFV 服务可操作性所必需的。安全参考架构的安全组件包括认证器、过滤器、安全日志记录器/审计员、基于角色的访问控制（RBAC）、受控虚拟地址空间（CVAS）和安全通道。认证器用于控制对 NFV 系统的访问，安全日志记录器/审计员用于跟踪所有安全活动，RBAC 用于基于角色实施授权权限；这三个框架在其系统中都使用了这三种安全机制。过滤器用于扫描 VNF 以去除恶意代码，这三个框架都使用了过滤器。过滤器也可以在 ETSI [17] 和 Red Hat 中以 Web 应用程序防火墙（WAF）的形式找到，它过滤和监控来自 Web 应用程序的流量。安全通道为网络服务提供完整性和保密性；这三个框架都使用了它，但它们在机制上可能有所不同；例如，Red Hat 使用传输层安全（TLS）来保护用户与其平台之间的通信[43]。CVAS 控制安全参考架构的使用权限，并且 CVAS 能够减轻特权提升和分布式拒绝服务（DDoS）攻击。这三个框架中的一些会使用额外的安全机制来减轻此类攻击；例如，云安全联盟（CSA）使用三个安全功能在恶意 DDoS 流量到达目标网络服务之前对其进行过滤。

可以发现我们的安全参考架构模型相当准确，因为其组件和安全机制与 NFV 安全框架的那些非常匹配。确实，这些 NFV 框架包含额外的安全措施，但如前所述，我们的安全参考架构是部分的，并未涵盖整个 NFV 系统的安全。当新的 NFV 安全框架发布时，可以进一步扩展验证。

5 相关工作

已经出现了几项关于 NFV 威胁和其他安全方面的调查，从 [34] 开始，包括我们自己的 [9]。最近，Pattaranantakul 等人 [46] 分析了五个 NFV 用例的安全威胁，以构建网络层威胁的分类法，然后比较安全机制，最后提出保护 NFV 服务的建议。Farris 等人 [47] 考虑了 NFV 在物联网系统中使用时的威胁，提供了引入 NFV 对安全影响的分析，描述了监测、保护和应对物联网安全威胁的策略。他们的论文还比较了物联网环境中的防御方法与传统安全对策。Wu 等人 [48] 分析了 NFV 的安全状态，并为基于 NFV 的管理和控制生态系统提出了安全实践；他们还识别了 NFV 的持续研究挑战和开放安全问题。

最近的一项调查考虑了 NFV 在 5G 中的使用 [7,49]；它探索了 5G 生态系统的复杂性，从中推导出一个 5G 电信商业模式，用于识别其攻击面的新方面，并列举了 NFV 支持的多种业务合作引入的安全威胁。该论文提出了一个基于 NFV 的 5G 网络的三维威胁分类法，将 NFV 架构与不同 5G 业务合作场景的部署用例相关联。物联网设备的激增带来了各种攻击，因为它们是网络切片的一个组成部分，需要特定的 QoS 和安全要求。与早期的调查不同，他们调查了层间、层内和跨管理域的威胁，并回顾了云计算、NFV 和 SDN 安全的现有调查以及一些 NFV 安全项目。还提供了增强这些网络安全的想法。

其他工作为 NFV 网络增加了安全措施。Basile 等人 [49] 引入了一种在 NFV 网络中自动执行安全政策以及对网络变化进行动态适应的方法。所提出的方法将高级安全要求转化为配置设置和网络安全功能（NSFs）的最佳选择。这些模型是基于 NSF 能力的形式化构建的，它描述了 NSFs 为执行安全政策目的可以做什么。一个网络安全功能（NSF）是一个用于确保网络通信的完整性、保密性或可用性，检测不需要的网络活动，或阻止或至少缓解不需要活动的影响的函数。他们认为这项工作是迈向安全政策感知 NFV 管理、编排和资源分配系统的第一步 —— 虚拟化网络管理的范式转变 —— 并且它需要对当前 NFV 架构进行微小的修改。

Alhebaishi 等人 [50] 使用一个部署模型来跟踪跨层级的漏洞，但他们不考虑这些层级的细节。Shameli - Sendi 等人 [51] 考虑了服务功能链的有效配置，以使用网络安全模式构建安全的客户网络。

[7,46 - 48] 中的调查是非常近期（2018 - 2021）且非常全面的；它们可以用来将我们的工作置于背景之中。[7] 提到了我们的一些工作，并指出我们的误用模式是 NFV 的第一批。同样基于这些调查和阅读一些论文，我们可以看到其他工作都没有提出误用模式或精确的架构模型，他们只是使用 ETSI 出版物的框图。事实上，ETSI 关于安全的出版物 [40,41] 只使用框图，而我们使用 UML，它更加精确。我们已经研究了上述参考文献以及其他文献以获得额外的细节。

6 结论和未来工作

NFV 是一种相对较新的技术，仍在发展中。到目前为止，大多数行业工作集中在标准、产品实现、性能和网络部署的研究上。当更多的 NFV 网络投入使用时，我们将看到它们的攻击增加。在安全方面已经有了相当多的工作，但在建模方面却不多，而建模对于提高它们的安全和使用是必要的。如相关工作部分所述，我们的模型是文献中唯一精确的模型，并且我们已经发表了 NFV 唯一的误用模式和 SRA。

我们在这里提出了一个安全参考架构，它展示了可以预期架构面临的重要威胁的位置，并指出了适当的防御措施。这个 SRA 虽然是部分的，但可以被产品开发者和研究人员用来实施防御并研究如何提高 NFV 网络的安全。我们还展示了 SRA 为复杂系统增加安全的价值。虽然可以使用像 ISO 标准中的防御列表那样添加安全防御，但 SRA 明确了在架构中应该应用防御的位置。我们的 SRA 基于先前发表的模式。

未来工作可以专注于通过编写新的误用模式扩展 SRA，这些模式可以发现架构特定位置对其他防御的需求。一个更完整的误用目录将增加这个 SRA 的实际价值。NFV 用于新的 5G 标准，我们的模型可能对其发展有价值。